Some employees from your company reported that they can't log into Outlook. The Exchange system admin also reported that he can't log in to the Exchange Admin Center. After initial triage, they discovered some weird readme files settled on the Exchange server.

Below is a copy of the ransomware note.


readme - Notepad

File Edit Format View Help

All of your files are currently encrypted by CONTI strain.

As you know (if you don't - just "google it"), all of the data that has been encrypted by our software cannot be recovered by any means without contacting our team directly. If you try to use any additional recovery software - the files might be damaged, so if you are willing to try - try it on the data of the lowest value.

To make sure that we REALLY CAN get your data back - we offer you to decrypt 2 random files completely free of charge.

You can contact our team directly for further instructions through our website :

TOR VERSION :
(you should download and install TOR browser first https://torproject.org)

http://conti[redacted].onion/

HTTPS VERSION :
https://conti[redacted]st

YOU SHOULD BE AWARE!
Just in case, if you try to ignore us. We've downloaded a pack of your internal data and are ready to publish it on out news website if you do not respond. So it will be bette

---BEGIN ID---
EdRBszpVz7I[redacted]Tg4J66nPSF
---END ID---

Below are the error messages that the Exchange admin and employees see when they try to access anything related to Exchange or Outlook.

Exchange Control Panel:


Server Error in '/ecp' Application.

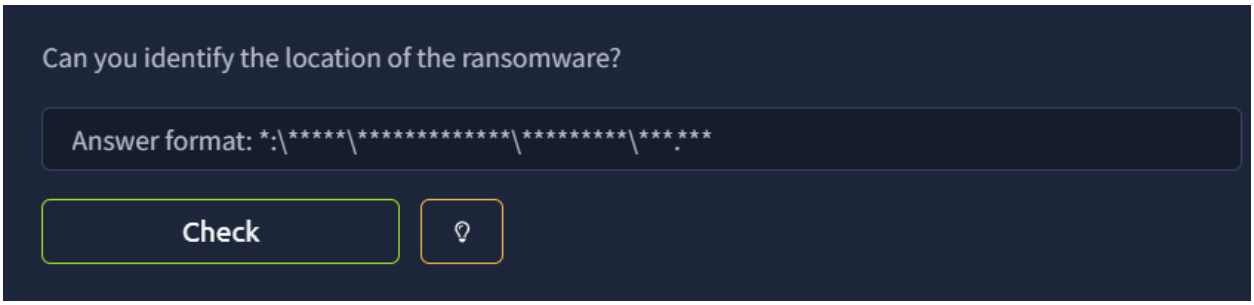
The resource cannot be found.

Outlook Web Access:

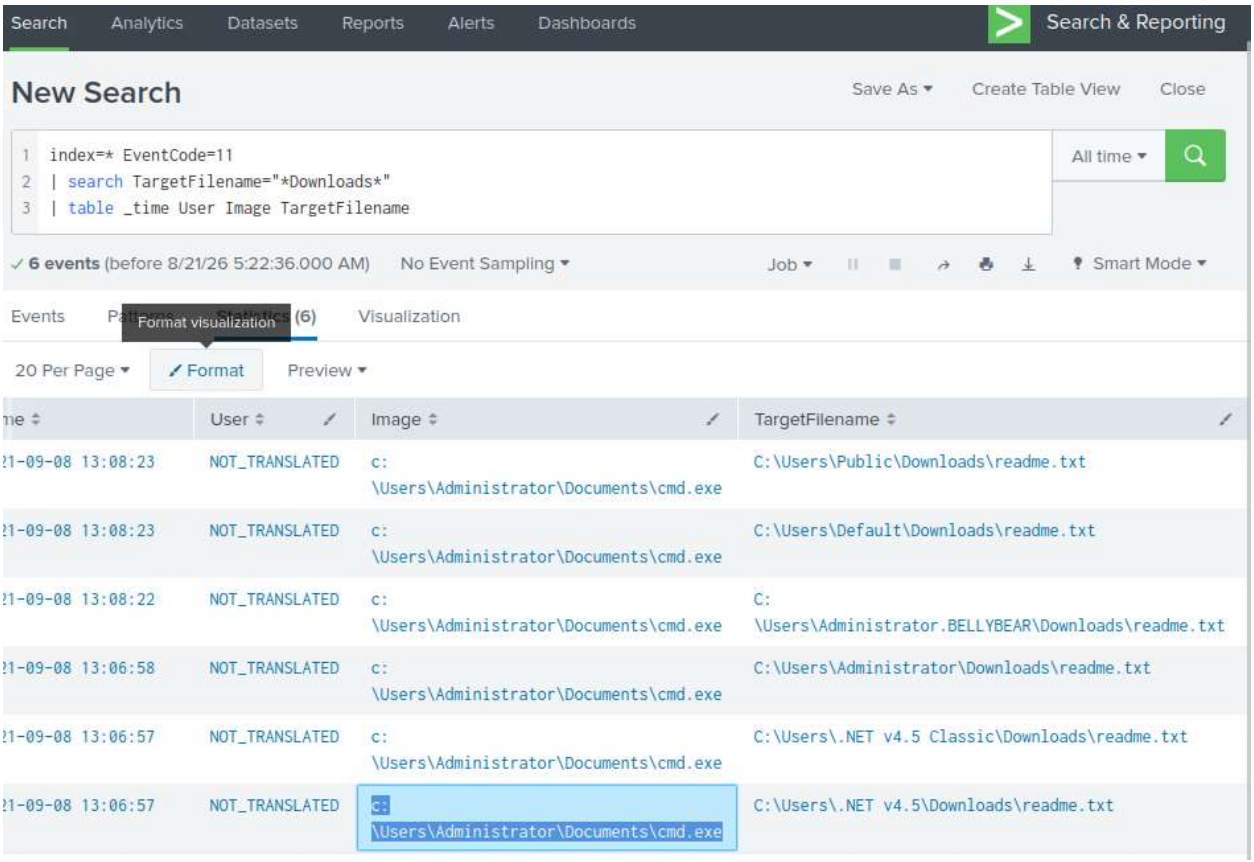

Server Error in '/owa' Application.

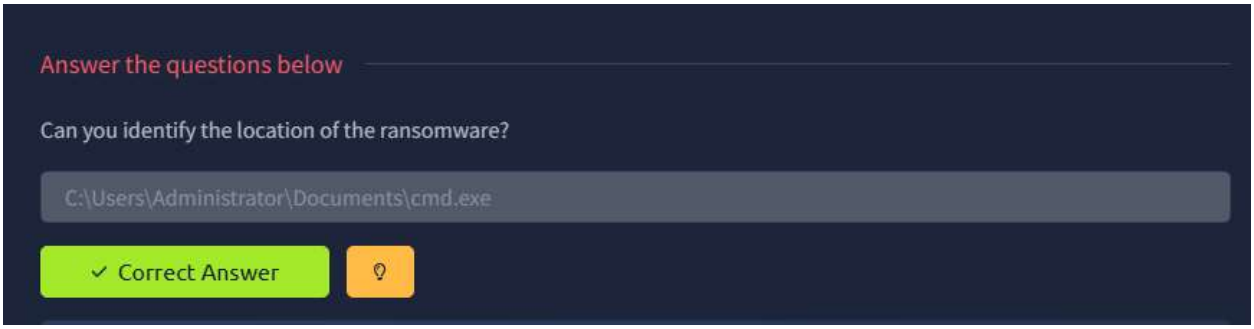
Parser Error

Task: You are assigned to investigate this situation. Use Splunk to answer the questions below regarding the Conti ransomware.



To find the location of the ransomware , It has to downloaded so we I will go through all the logs with a query that list me all of them





so the ransomware is named cmd.exe because the legitimate resides in System32 Directory

What is the Sysmon event ID for the related file creation event?

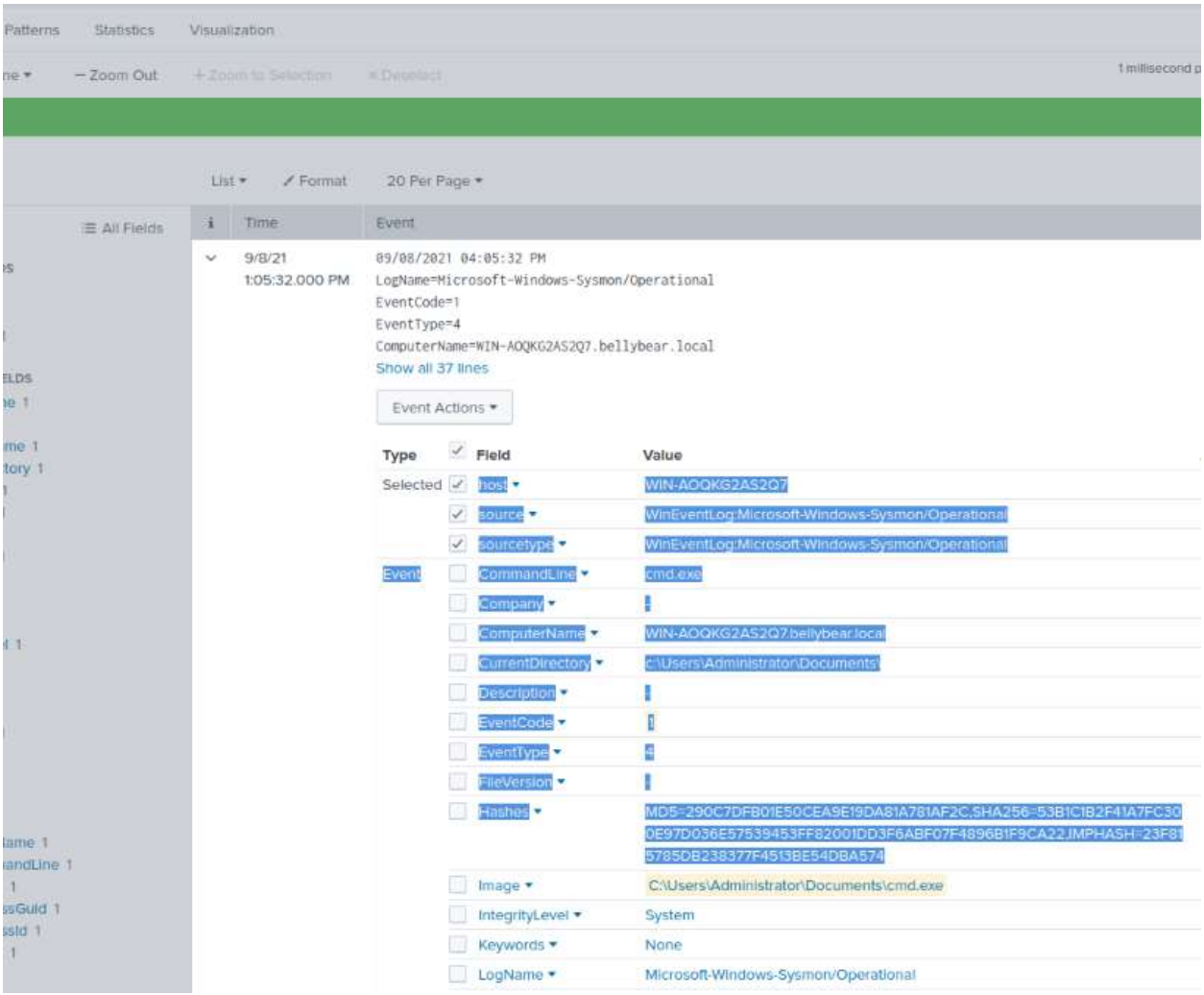
11

✓ Correct Answer

Can you find the MD5 hash of the ransomware?

Answer format: **********

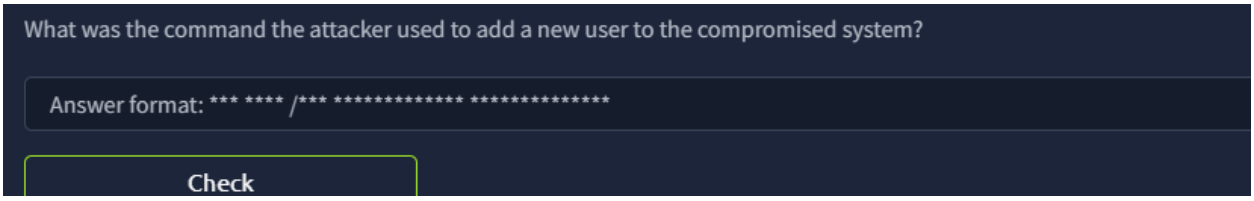
Check



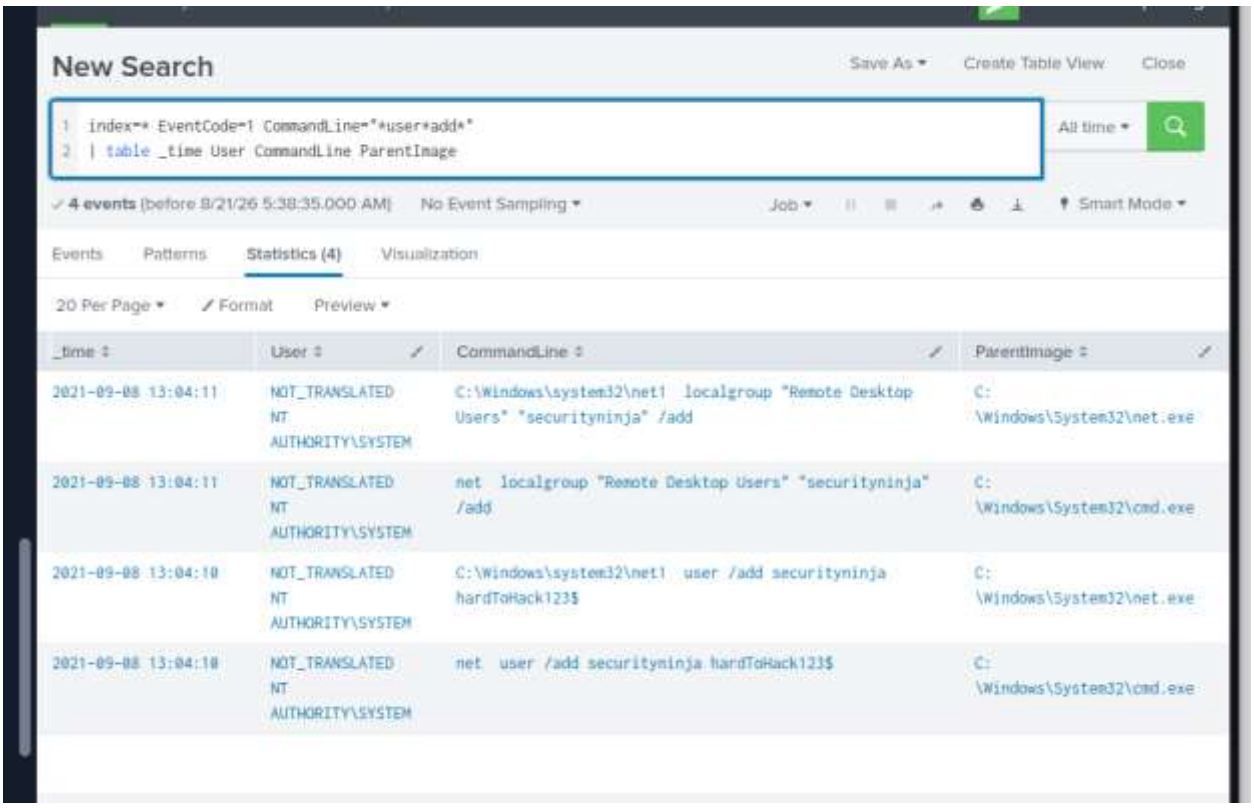
the md5 hash for given within the metadata of the event



as the ransomware was encrypting it kept on dropping “readme.txt” file on multiple locations



to find the added user we will search for keywords “add” “net” in commands



What was the command the attacker used to add a new user to the compromised system?

net user /add securityninja hardToHack123$

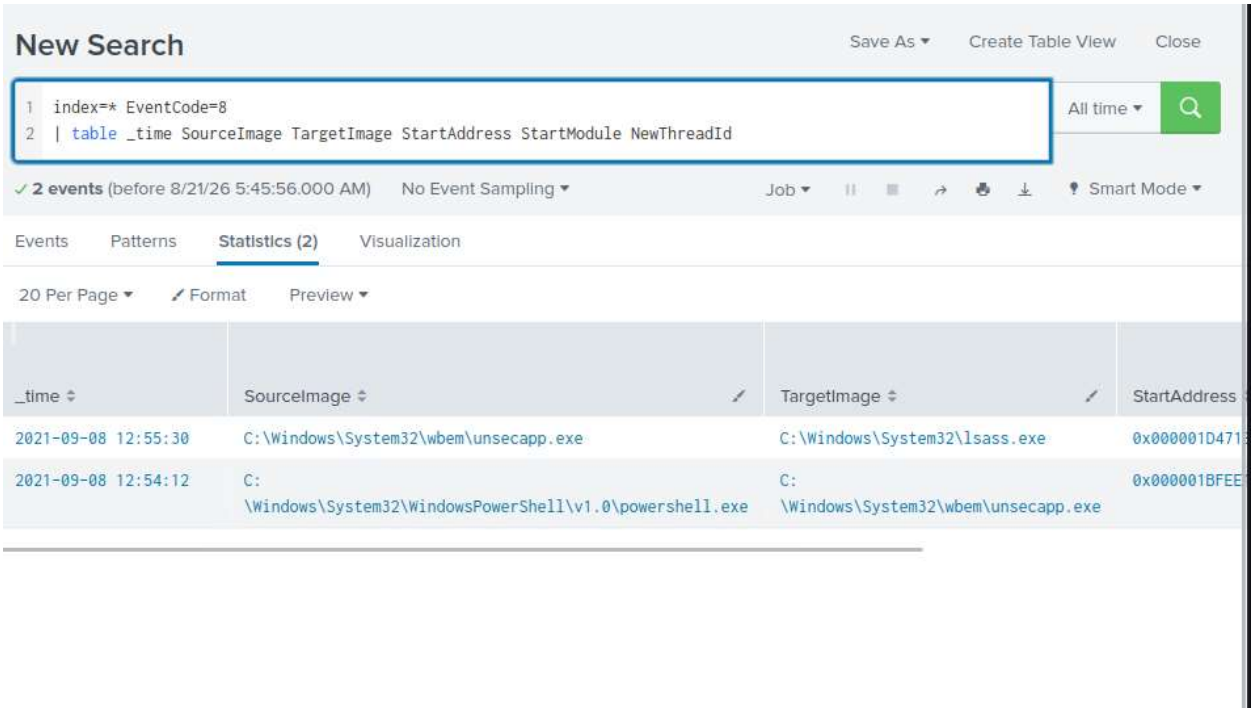
✓ Correct Answer

The attacker migrated the process for better persistence. What is the migrated process image (executable), and what is the original process image (executable) when the attacker got on the system?

Answer format: *:**********************************.*************.***;:****************************.***

Check

This is a classic technique of Process injection where an attacker inserts and executes malicious code within the address space of a legitimate running process, allowing the malware to operate under the identity and privileges of that trusted process



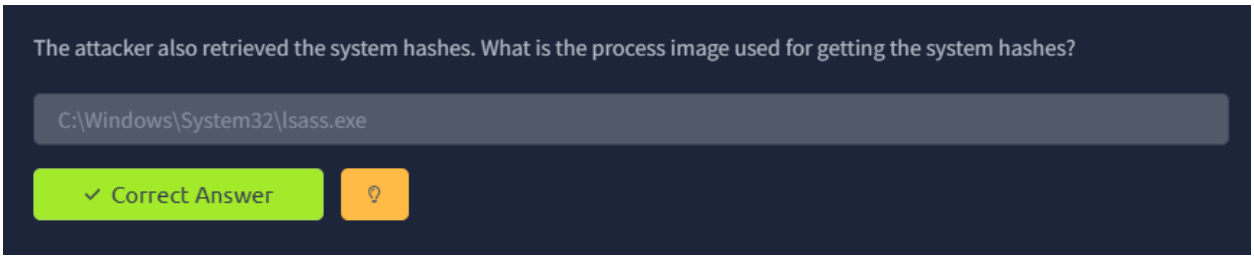
after making a search query for that I found this , I caught both processes perforing the similar technique

`unsecapp.exe` is a legitimate Windows WMI component so the attacker opted for it for his hiding spot later he used the same process to dump lsass memory which

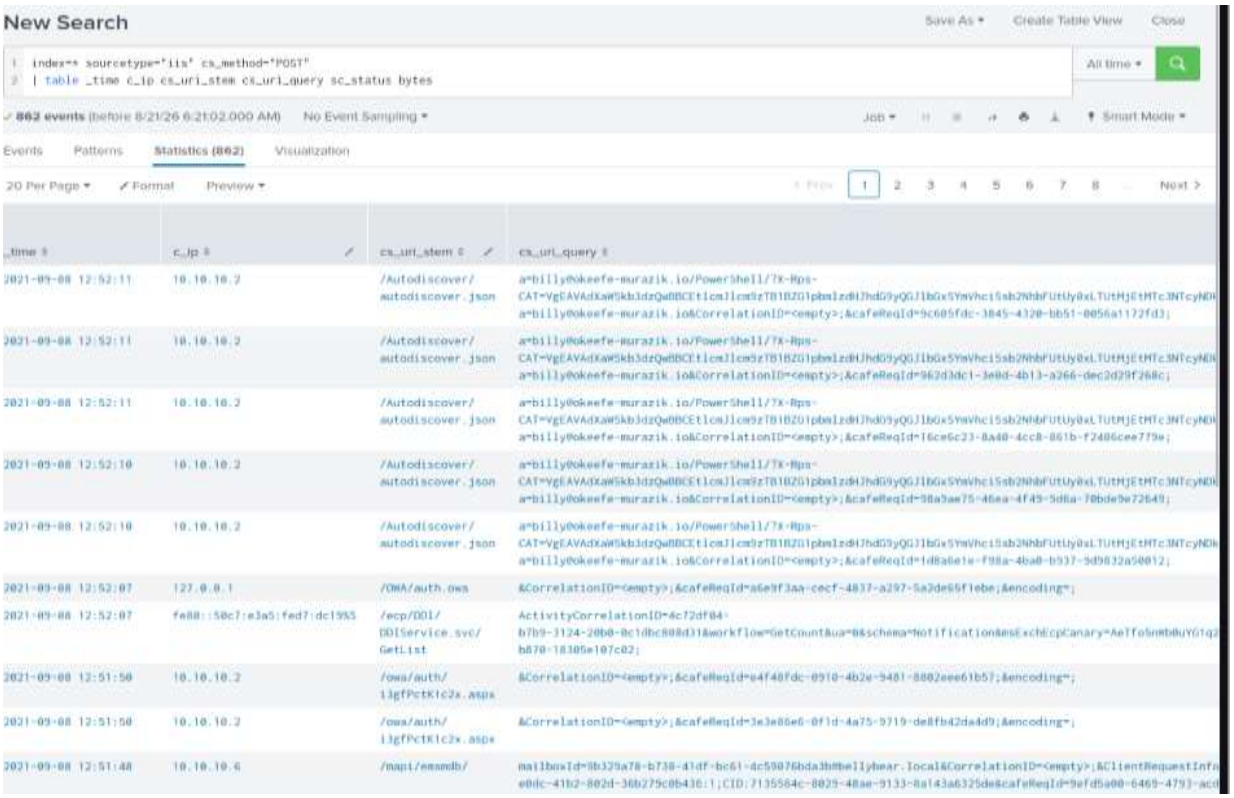
`lsass.exe` = Local Security Authority Subsystem Service — it holds in memory:

- NTLM hashes
- Kerberos tickets
- Plaintext passwords (in older configs)

Every attacker wants inside it. It's basically Windows' password vault walking around in RAM.



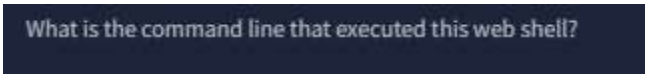




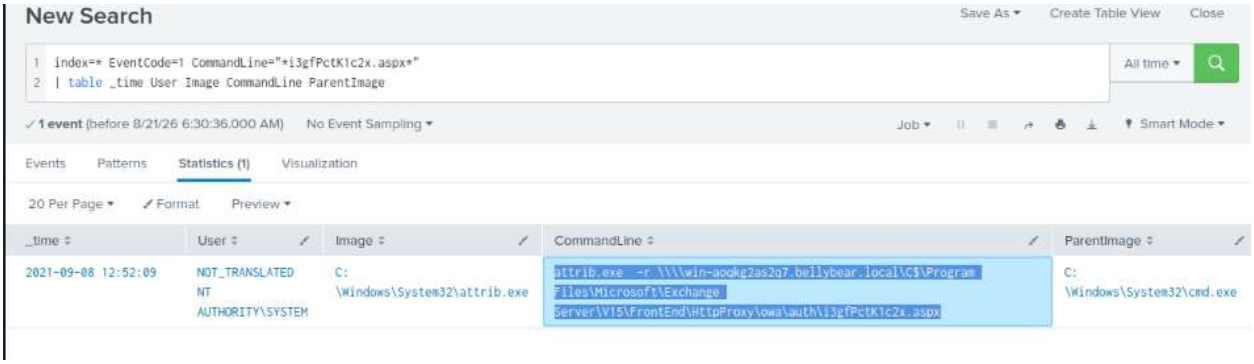
to hunt for the webshell it has to be uploaded not only that since the compromised server was of

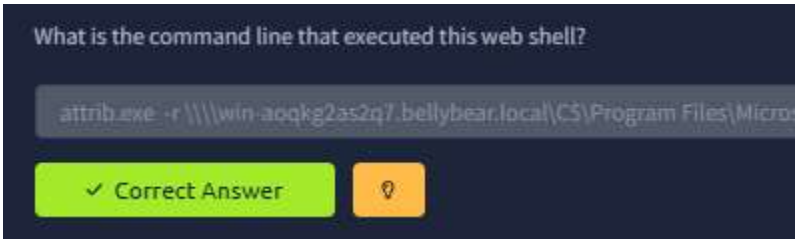
IIS I have to look for any abnormal **.aspx** file on the system

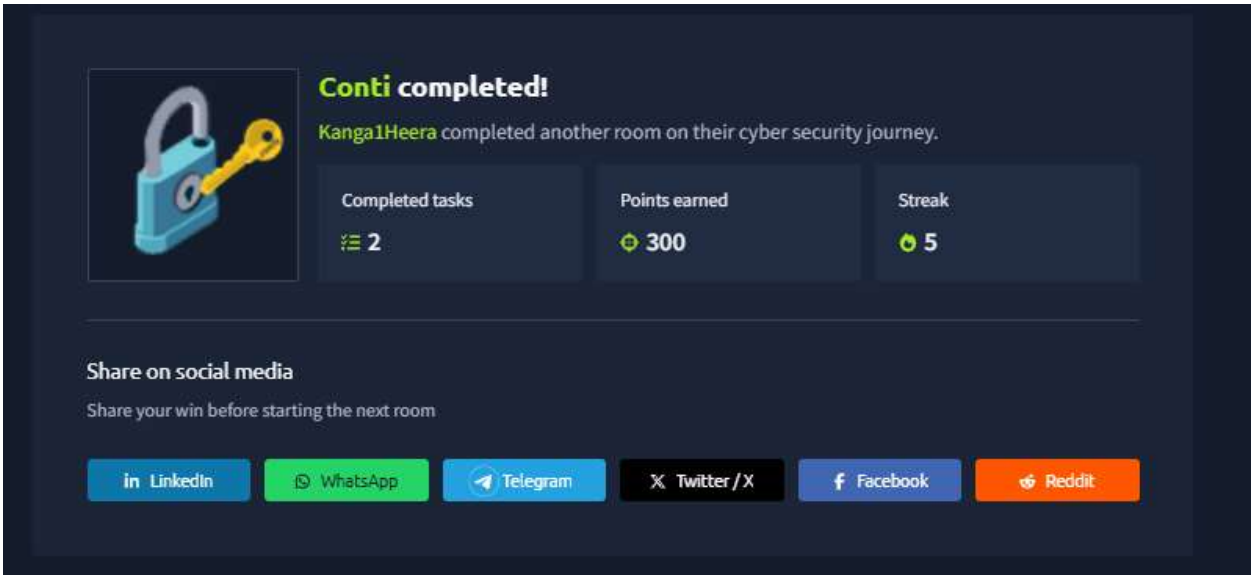




after the file was uploaded the attacker executed it from the compromised windows machine with the following commands







This wraps up conti ransomware investigation